SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA51

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario-Based : 20%

Total Marks: 50

Annexure A

Code of Conduct:

I **C. PRIYANKA / 192511074** *certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **C. PRIYANKA**

Annexure A

1. Secure Password Storage in Web Applications

A web application stores user passwords and needs to protect them against database breaches.

A. Explain why storing plaintext passwords is insecure.
B. Suggest a secure method for storing passwords and justify your choice.

ANSWER:

A. Explain why storing plaintext passwords is insecure.

Plaintext passwords are passwords stored in a database in their original, readable form without any protection.

Storing passwords in plaintext is insecure because if an attacker gains access to the database, they can easily read and steal all the users' passwords.

Reasons why plaintext password storage is insecure:

1. **Easy to steal:** Attackers can directly read passwords from the database.
2. **Account compromise:** Attackers can use stolen passwords to log in to users' accounts.
3. **Password reuse attacks:** If users use the same password for multiple websites, attackers may access their other accounts.
4. **Loss of privacy:** Attackers may gain access to personal information, financial details, and confidential data.
5. **Damage to reputation:** A data breach can reduce users' trust in the application and cause financial losses to the organization.

Example:

Suppose a website stores the following information in its database:

Username	Password
Priya123	Priya@123
Ravi456	Ravi@456

Username	Password
Anu789	Anu@789

If an attacker accesses this database, they can immediately see the users' passwords and misuse them.

Therefore, storing passwords in plaintext is dangerous and must be avoided.

B. Suggest a secure method for storing passwords and justify your choice.

Recommended method: Password Hashing with Salt

Password hashing is a security technique that converts a password into a fixed-length value using a one-way cryptographic algorithm. A salt is a unique, randomly generated value added to each password before hashing.

Recommended algorithms:

- Argon2id
- bcrypt
- scrypt

Among these, **Argon2id is an excellent choice for securely storing passwords in modern web applications.**

How password hashing works:

1. The user creates a password.
2. The application generates a unique random salt.
3. The password and salt are processed using Argon2id.
4. The application stores the resulting password hash and the information needed to verify it, including the salt and algorithm parameters.
5. When the user logs in, the application processes the entered password using the stored salt and parameters.
6. The application verifies whether the entered password matches the stored hash. If it matches, the user is authenticated.

Example:

Original password: Priya@123

The application processes the password using Argon2id with a unique salt.

Stored information: A password hash, salt, and the required algorithm parameters.

The original password is not stored in the database.

Advantages:

1. **One-way protection:** The hash is designed to be computationally infeasible to reverse directly into the original password.
2. **Protection against database breaches:** Attackers cannot immediately read the original passwords from the stored hashes.
3. **Salt prevents identical hashes for identical passwords:** Different salts ensure that users with the same password normally have different stored hashes.
4. **Resistance to password guessing:** Argon2id is designed to make password guessing more expensive by using configurable computational and memory resources.
5. **Secure authentication:** The application can verify passwords without storing their original values.

Conclusion: Passwords should be stored using a dedicated password-hashing algorithm such as Argon2id, with a unique salt for every password. This greatly reduces the risk of password theft and misuse if the database is compromised.

---

2. Digital Signature for Document Authentication
A company wants to ensure that official documents sent electronically are authentic and unaltered.

A. Explain how digital signatures can be used in this scenario.
B. Justify how this method ensures both integrity and non-repudiation.

ANSWER:

A. Explain how digital signatures can be used in this scenario.

A **digital signature** is a cryptographic technique used to verify the authenticity and integrity of an electronic document. It uses public-key cryptography to help establish that a document was signed by the holder of a particular private key.

A digital signature uses two keys:

- **Private key:** Used by the document signer to create the digital signature.

- **Public key:** Used by the recipient to verify the digital signature.

Working of a digital signature:

1. **Document creation:** The company prepares an official document, such as an electronic contract.
2. **Hash generation:** A cryptographic hash function, such as SHA-256, generates a hash of the document.
3. **Signature creation:** The signer uses their private key to create a digital signature over the document hash.
4. **Document transmission:** The company sends the document and its digital signature to the recipient.
5. **Signature verification:** The recipient uses the signer's public key to verify the signature.
6. **Integrity verification:** The recipient checks that the signature is valid for the received document. Any unauthorized change to the document will normally cause verification to fail.

Example:

Suppose a company sends an electronically signed employment contract to an employee.

The company signs the contract using its private key. The employee verifies the signature using the company's trusted public key or a valid digital certificate.

If the signature verifies correctly, the employee obtains evidence that the document is associated with the holder of the signing key and that the signed content has not been altered since signing.

B. Justify how this method ensures both integrity and non-repudiation.

Digital signatures provide important security properties, including integrity and support for non-repudiation.

1. Integrity

Integrity means ensuring that information has not been changed without authorization.

A digital signature is created for the document's contents. If an attacker changes even a small part of the signed document, the signature will normally fail verification.

Example:

Original contract amount: ₹50,000

Modified contract amount: ₹90,000

Because the document has changed, verification of the original digital signature against the modified document will fail.

Therefore, digital signatures help detect unauthorized modifications.

2. Non-repudiation

Non-repudiation means providing evidence that helps prevent a signer from credibly denying having signed a document.

A digital signature is created using the signer's private key. A successful verification with the corresponding public key provides evidence that the signature was generated using the corresponding private key.

For stronger non-repudiation, the organization should also:

- Use a valid digital certificate that links the public key to the signer's verified identity.
- Protect the private key from unauthorized use.
- Maintain reliable records of the signing process.
- Use a trusted timestamp when proof of signing time is important.

Example:

A company digitally signs an agreement with a business partner. Later, the company disputes the agreement.

A valid digital signature, supported by a trusted certificate and reliable signing records, can provide evidence that the document was signed using the company's private key.

However, a digital signature alone does not prove who physically used the private key. Its evidentiary strength depends on key protection, identity verification, and the surrounding circumstances.

Conclusion: Digital signatures help ensure document integrity by detecting modifications and support non-repudiation by providing verifiable evidence associated with the signer's private key.

3. Preventing Replay Attacks in Online Transactions
An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

A. Explain how replay attacks occur.
B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

ANSWER:

A. Explain how replay attacks occur.

A **replay attack** is a security attack in which an attacker captures a valid message or transaction and retransmits it later to make the system perform an unauthorized or unintended action.

The attacker may not need to decrypt or modify the original message. Simply resending a previously valid message may be sufficient if the system does not check whether it has already been used.

How a replay attack occurs:

1. A customer initiates a legitimate online payment.
2. The payment request is transmitted over a network.
3. An attacker captures a copy of the request.
4. The attacker sends the same request to the payment server again.
5. If the server does not detect the duplicate request, it may process the payment more than once.

Example:

Suppose a customer sends a payment request to transfer ₹1,000.

An attacker captures the request and resends it several times.

If the payment server does not have replay protection, the server might process the same payment repeatedly, resulting in multiple transfers.

Effects of replay attacks:

- Duplicate payments or transactions.
- Unauthorized financial loss.
- Repeated execution of the same operation.

- Reduced trust in the online payment system.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

Recommended technique: Cryptographic Nonces and Timestamps

A nonce is a unique value used to ensure that a message or transaction is not accepted more than once. A timestamp records when the transaction was created.

For an online payment system, the server can combine these mechanisms with a message authentication code (MAC) or digital signature.

How the technique works:

1. **Generate a unique nonce:** The payment system creates a unique transaction identifier or nonce for each transaction.
2. **Authenticate the request:** The system uses a MAC or digital signature to protect the transaction details, including the nonce and other relevant fields.
3. **Send the request:** The customer submits the authenticated payment request to the server.
4. **Verify authenticity:** The server checks the MAC or digital signature.
5. **Check freshness:** The server verifies that the timestamp falls within an acceptable time window, if timestamps are used.
6. **Check the nonce:** The server checks whether the nonce or transaction identifier has already been used.
7. **Reject duplicates:** If the transaction has already been processed, the server rejects the repeated request rather than executing the payment again.

Example:

A payment request contains:

- Transaction ID: TXN1001
- Amount: ₹1,000
- Timestamp: 10:00 AM
- Authentication: A valid MAC or digital signature

When the request arrives for the first time, the server verifies it and processes the payment.

If an attacker resends the same request, the server recognizes TXN1001 as an already processed transaction and rejects the duplicate.

Advantages:

1. **Prevents duplicate processing:** Used transaction identifiers can be recorded and checked.
2. **Detects stale requests:** Timestamps can help reject requests that are too old.
3. **Protects message authenticity:** A MAC or digital signature helps prevent attackers from changing transaction details without detection.
4. **Improves transaction security:** The server can distinguish new requests from previously processed requests.

Important point: A timestamp alone is insufficient because an attacker may replay a request within the allowed time window. Similarly, a nonce is effective only when the server checks and records its use reliably. The server should also process transaction identifiers atomically to prevent concurrent duplicate requests.

Conclusion: A combination of unique transaction identifiers or nonces, timestamps, cryptographic authentication, and server-side duplicate detection is an effective way to prevent replay attacks in online payment systems.

---

4. Secure Communication over Public Wi-Fi
A user accesses sensitive information using a public Wi-Fi network without encryption.

A. Identify the risks involved in this scenario.
B. Recommend a secure communication method and justify how it protects user data.

ANSWER:

A. Identify the risks involved in this scenario.

Public Wi-Fi networks are commonly available in places such as railway stations, airports, cafés, hotels, and shopping malls.

When a user accesses sensitive information over a public Wi-Fi network without encryption, attackers connected to the same network may be able to intercept or manipulate network traffic.

Major risks:

1. Data interception

Attackers may capture network traffic and read sensitive information if it is transmitted without encryption.

Example: A user sends a password over an unencrypted connection, and an attacker captures it.

2. Man-in-the-middle attacks

An attacker positions themselves between the user and the intended server to intercept or modify communications.

Example: A user accesses a fake banking page through a malicious Wi-Fi hotspot.

3. Password theft

If login credentials are transmitted without adequate protection, attackers may steal them and gain access to the user's accounts.

4. Session hijacking

An attacker may steal a session cookie or token and use it to impersonate an authenticated user.

5. Fake Wi-Fi hotspots

Attackers may create a hotspot with a name similar to that of a legitimate café or airport network to trick users into connecting.

6. Data manipulation

Without appropriate integrity protection, attackers may modify unprotected network traffic, potentially changing information exchanged between the user and a server.

Conclusion: Using public Wi-Fi without encryption can expose sensitive information to interception, theft, impersonation, and manipulation.

B. Recommend a secure communication method and justify how it protects user data.

Recommended method: HTTPS using TLS, with a trusted VPN when appropriate.

HTTPS is the secure version of HTTP. It uses Transport Layer Security (TLS) to protect communication between a web browser and a website.

A Virtual Private Network (VPN) can provide an additional encrypted tunnel between the user's device and the VPN provider. However, a VPN does not replace HTTPS.

1. HTTPS and TLS

HTTPS protects data transmitted between the browser and the website.

How HTTPS works:

1. The user opens a website using HTTPS.
2. The browser establishes a TLS connection with the website.
3. The browser verifies the website's digital certificate and identity.
4. The browser and server establish session keys through the TLS handshake.
5. Data is encrypted and authenticated using those keys.
6. The website and browser exchange protected information.

Security benefits:

- **Confidentiality:** Encryption makes intercepted traffic difficult to read.
- **Integrity:** Cryptographic authentication detects unauthorized changes to protected traffic.
- **Server authentication:** Certificate verification helps the browser confirm that it is communicating with the intended website.

Example:

A user accesses an online banking website over HTTPS while connected to public Wi-Fi.

Even if an attacker captures the network traffic, properly protected TLS communication prevents the attacker from simply reading the banking password or transaction details from that traffic.

However, HTTPS does not protect against every threat. For example, it cannot guarantee protection if the user enters credentials into a convincing fake website or if the user's device is compromised.

2. Virtual Private Network (VPN)

A VPN creates an encrypted tunnel between the user's device and a VPN server.

Advantages of a VPN:

- Encrypts traffic between the device and the VPN server.
- Helps protect traffic from local network observers.
- Can reduce exposure when using untrusted Wi-Fi networks.

Example:

A student uses public Wi-Fi to access university resources. A trusted VPN encrypts traffic between the student's device and the VPN server, reducing the ability of other users on the local Wi-Fi network to inspect that traffic.

However, the VPN provider may be able to observe some traffic metadata, and a VPN does not automatically make every website or application secure.

Best practices for secure communication

1. Use HTTPS websites and check for valid certificate warnings.
2. Use a reputable VPN when appropriate, especially for untrusted networks.
3. Avoid accessing sensitive accounts through suspicious websites.
4. Enable multifactor authentication (MFA).
5. Keep the operating system, browser, and applications updated.
6. Disable automatic connection to unknown Wi-Fi networks.

Conclusion: HTTPS with TLS is essential for protecting data exchanged with websites. A trusted VPN can provide an additional layer of protection on public Wi-Fi, but it should be used alongside HTTPS rather than as a replacement for it.

---

5. Data Integrity in Cloud Storage
An organization stores critical data in a cloud server and wants to ensure that the data is not altered.

A. Explain how hashing can be used to verify data integrity.
B. Suggest an additional mechanism to enhance trust and justify your answer.

ANSWER:

A. Explain how hashing can be used to verify data integrity.

Hashing is a cryptographic technique that converts data of any length into a fixed-length value called a hash or message digest.

A cryptographic hash function, such as SHA-256, produces a digest that can be used to detect changes in data.

Even a small modification to the original data will normally produce a different hash value.

How hashing verifies data integrity:

1. **Original data:** An organization prepares a file containing important information.
2. **Hash generation:** The organization calculates the file's hash using SHA-256.
3. **Hash storage:** The organization stores the hash in a trusted location.
4. **Data upload:** The file is uploaded to the cloud server.
5. **Hash recalculation:** When the file is downloaded or checked, the organization calculates its hash again.
6. **Comparison:** The new hash is compared with the original trusted hash.
7. **Verification:** If the hashes match, this provides strong evidence that the file has not changed. If they differ, the file may have been modified or corrupted.

Example:

Suppose an organization stores a confidential report in cloud storage.

Original file hash:

A1B2C3D4...

After downloading the file, the organization calculates its hash again.

Case 1: Hashes match

Original hash = Downloaded file hash.

This provides evidence that the downloaded file matches the original data.

Case 2: Hashes differ

Original hash ≠ Downloaded file hash.

This indicates that the file may have been altered or corrupted.

The organization should investigate the difference before trusting the file.

Advantages of hashing

1. **Detects modifications:** Changes to the data normally result in a different hash.
2. **Efficient verification:** Hashes can be compared without comparing every byte manually.
3. **Detects accidental corruption:** Hashing helps identify errors that occur during storage or transmission.
4. **Supports cloud security:** Organizations can verify whether downloaded files match their trusted original versions.
5. **Useful for large files:** Cryptographic hashes provide a practical way to verify the integrity of large datasets.

Important limitation: Hashing alone does not prove that the data is authentic. If an attacker can change both the file and its stored hash, the attacker may replace the original data and calculate a matching new hash.

Therefore, the original hash must be protected or authenticated.

B. Suggest an additional mechanism to enhance trust and justify your answer.

Recommended mechanism: Digital Signatures

Digital signatures can strengthen trust in cloud storage by allowing an organization to verify the authenticity and integrity of stored data.

A digital signature uses the signer's private key to sign a cryptographic representation of the data. The recipient verifies the signature using the corresponding public key.

How digital signatures enhance trust:

1. **Generate a hash:** The organization calculates the SHA-256 hash of the original file.
2. **Create a signature:** The organization signs the file's hash or otherwise signs the file using a suitable digital-signature scheme and its private key.
3. **Upload the data:** The organization uploads the file and its digital signature to the cloud server.
4. **Download the file:** An authorized user downloads the file and signature.

5. **Verify the signature:** The user verifies the signature using the organization's trusted public key.
6. **Confirm integrity and authenticity:** If verification succeeds, it provides evidence that the signed data has not been modified since signing and that the signature corresponds to the associated private key.

Example:

A hospital stores patient records in cloud storage.

The hospital digitally signs an important medical report before uploading it.

Later, an authorized doctor downloads the report and verifies its digital signature using the hospital's trusted public key.

If an attacker modifies the report, signature verification should fail. This helps the doctor detect unauthorized changes and verify that the report is associated with the hospital's signing key.

Other mechanisms that can improve cloud data integrity

In addition to digital signatures, the organization can use:

1. Message Authentication Code (MAC)

A MAC uses a secret key to authenticate a message and detect unauthorized modifications.

It is suitable when the communicating parties share a secret key. Unlike a digital signature, it does not provide the same public-verification capability.

2. Access control

Access control restricts who can view, modify, or delete stored data.

For example, only authorized administrators may be permitted to modify critical records.

3. Versioning and audit logs

Versioning keeps earlier copies of files, while audit logs record relevant operations.

These mechanisms help organizations investigate unauthorized changes and recover previous versions when necessary.

4. Trusted backups

Regular backups allow organizations to recover data if it is corrupted, accidentally deleted, or maliciously modified.

Conclusion: Hashing helps detect changes to cloud-stored data, but a trusted hash is necessary for reliable verification. Digital signatures provide stronger evidence of data authenticity and integrity, while access control, versioning, audit logs, and backups provide additional protection.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand